



AI-POWERED SOC L1 SECURITY OPERATIONS

& Incident Response Automation

Project Design & Technical Documentation

Technology Stack: n8n • Splunk • Google Gemini • VirusTotal • Jira • Gmail • Cloudflare Tunnel

Prepared as part of a Security Operations Center (SOC) automation initiative demonstrating agentic AI investigation, SIEM correlation, threat-intelligence enrichment, and incident-management workflow design.

Document Version 1.0

Table of Contents

1. Executive Summary	3
2. Project Objectives	3
3. Scope	4
4. System Architecture Overview	5
5. Detailed Workflow Walkthrough	8
6. AI Agent Architecture — Reasoning Framework	10
7. Alert Data Model.....	13
8. External Integrations	13
9. Classification, Severity, and Escalation Logic.....	15
10. Sample Investigation Walkthrough	16
11. Security and Governance Considerations.....	18
12. Testing and Validation Approach	19
13. Known Limitations and Observations.....	20
14. Future Enhancements	20
15. Skills Demonstrated	22
16. Roles and Responsibilities	23
17. Conclusion	24
Appendix A — Sample Alert Payload	25
Appendix B — Repository Structure	26
Appendix C — Tools & Technologies Reference.....	26
Appendix D — Glossary of Terms	26

1. Executive Summary

This document describes the design, architecture, and operational logic of an AI-powered Security Operations Center (SOC) Level 1 automation platform built on n8n Cloud. The platform automates the full lifecycle of a security alert — from ingestion through triage, investigation, enrichment, classification, documentation, and escalation — using a two-stage agentic AI pipeline backed by Google Gemini large language models.

Security alerts arrive over a webhook and are normalized into a structured schema before being handed to an AI agent that performs first-line SOC L1 triage. The agent queries Splunk for corroborating log evidence, applies a structured investigation methodology, and produces a preliminary classification and severity rating. A second AI agent then performs threat-intelligence enrichment against VirusTotal, finalizes the investigation narrative, and automatically creates a Jira incident ticket containing the full findings. Stakeholders are notified by email once the investigation completes, and incidents that meet a high-severity threshold are automatically escalated to Level 2 (L2) analysts through a dedicated notification.

The workflow demonstrates practical application of agentic AI to a real SOC analyst workflow: it encodes the standard ALERT → TRIAGE → VALIDATE → INVESTIGATE → CORRELATE → CLASSIFY → ESCALATE/RESPOND → DOCUMENT methodology directly into the system prompts governing each AI agent, and it constrains the agents with explicit guardrails against fabricating tool output, taking destructive action, or overriding human-provided classification without evidence.

This document is organized to walk through the system's objectives, its architecture, each workflow node and its function, the AI agents and the reasoning framework they follow, the external tool integrations, the data model used to represent an alert, the escalation logic, a worked example, security and governance considerations, known limitations, and a roadmap for future enhancement.

Taken together, the workflow illustrates a broader point about applying large language models to security operations: the value of the AI is not in replacing analyst judgment but in reliably executing the repetitive, evidence-gathering portions of triage — querying the SIEM, checking indicator reputation, and writing up findings in a consistent format — so that human analysts can spend their attention on the alerts and decisions that genuinely require it.

2. Project Objectives

The project was designed to explore how agentic AI, orchestrated through a low-code automation platform, can reduce the manual burden on SOC L1 analysts while preserving the rigor and auditability that security operations require. The specific objectives are:

1. Automate first-line triage of inbound security alerts (phishing emails, suspicious URLs, malicious file hashes, anomalous source IPs, and failed authentication events) without requiring an analyst to manually open a SIEM console for every alert.
2. Ground AI-generated findings in real evidence by requiring the AI agents to actively query Splunk and VirusTotal rather than reasoning from the alert text alone.
3. Produce a consistent, structured investigation record for every alert, suitable for direct inclusion in a Jira incident, regardless of alert type.
4. Apply a repeatable classification and severity model (True Positive / False Positive / Suspicious, and Low / Medium / High / Critical) so that downstream triage and reporting remain comparable across incidents.
5. Automatically escalate confirmed, high-severity incidents to a Level 2 (L2) team through email, reducing time-to-escalation for the alerts that matter most.
6. Maintain a human-in-the-loop safety boundary: the AI agents are explicitly prohibited from performing destructive or high-impact response actions (e.g., isolating a host, disabling an account, blocking an IP) without human approval.
7. Keep the architecture modular and vendor-agnostic where possible, so that the SIEM, threat-intel, or ticketing components could be swapped without redesigning the investigation logic.

3. Scope

3.1 In Scope

- Ingestion of security alerts via an HTTP webhook, covering phishing emails, suspicious URL reports, and indicator-bearing alerts (source IP, file hash).
- Two-stage AI-driven investigation: an initial SOC L1 triage agent and a secondary enrichment/documentation agent.
- Splunk-based log correlation, with an emphasis on Windows authentication event codes for failed-login scenarios.
- VirusTotal-based reputation lookups for IP addresses, domains, URLs, and file hashes.
- Automatic Jira incident creation with a structured investigation description.
- Email notification on investigation completion and a separate, conditional email escalation for high-severity True Positive incidents.
- Secure connectivity between the cloud-hosted n8n instance and an on-premises/local Splunk deployment via Cloudflare Tunnel.

3.2 Out of Scope

- Automated remediation or containment actions (e.g., host isolation, account lockout, firewall rule changes). These remain manual, human-approved actions.
- SOC L2/L3 deep-dive forensic investigation, malware reverse engineering, or root-cause analysis beyond L1 triage.
- Alert generation itself — the workflow assumes alerts are produced upstream (e.g., by an email security gateway, EDR, or SIEM correlation rule) and delivered to the webhook.

- Long-term metrics, dashboards, or SOC KPI reporting (mean time to detect/respond, alert volume trending, etc.), which are noted as future enhancements.

4. System Architecture Overview

The platform is implemented as a single n8n workflow, orchestrated entirely within n8n Cloud, that chains together a webhook trigger, a field-normalization step, two LangChain-based AI agent nodes (each backed by Google Gemini and equipped with distinct tools), a conditional branch, and email notification nodes. The high-level flow is summarized below.

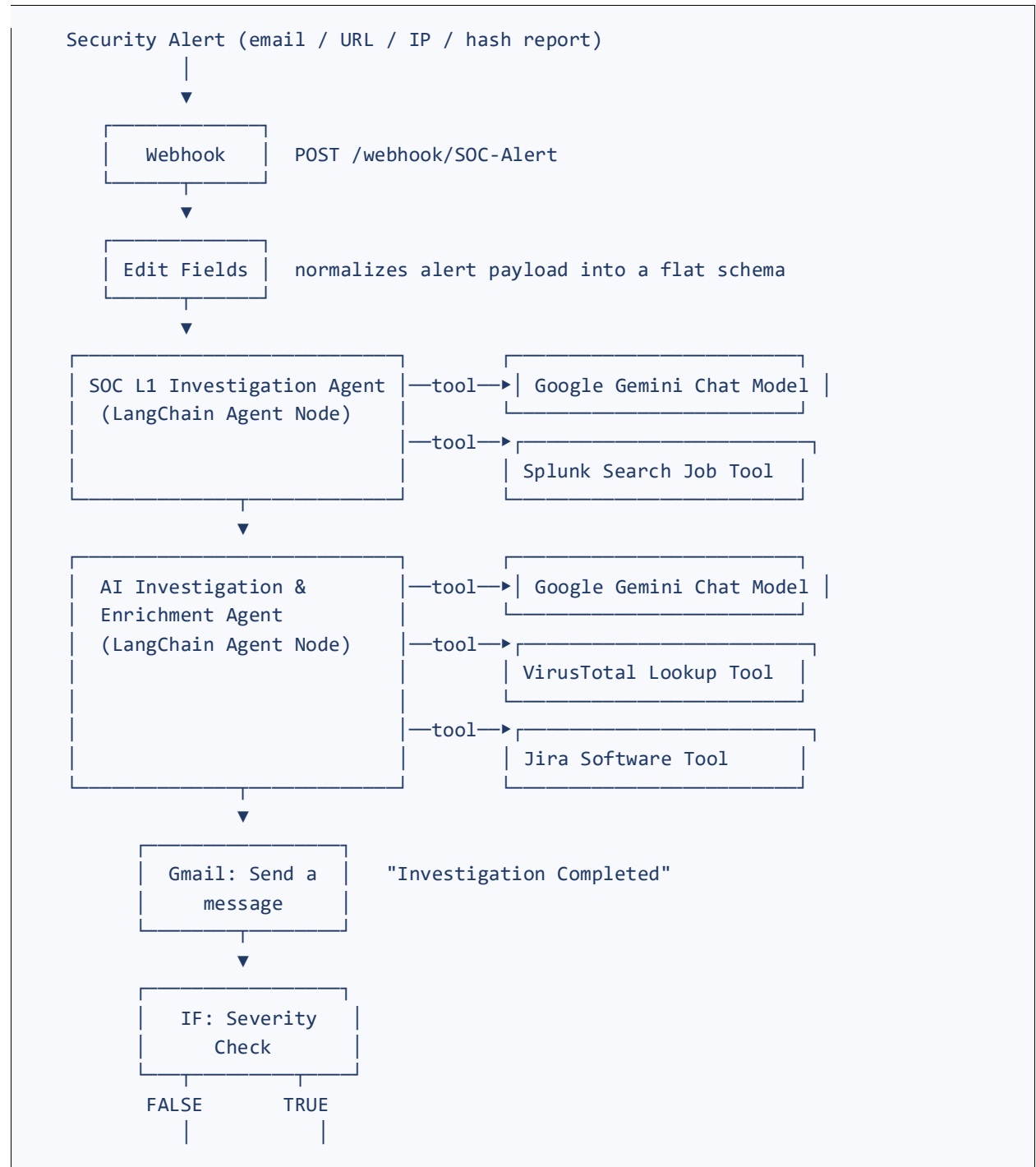




Figure 1 — End-to-end n8n workflow topology

The design intentionally separates concerns across the two AI agent nodes. The first agent is scoped narrowly to triage and Splunk-based log investigation; it does not have access to VirusTotal or Jira. The second agent receives the first agent's output as context and is responsible for external threat-intelligence enrichment and formal incident documentation. This separation keeps each agent's tool surface small and its system prompt focused, which improves the reliability of tool selection and reduces the chance that either agent skips a required step.

4.1 Component Summary

Component	Role in the Workflow	Technology
Alert Intake	Receives the inbound alert as an HTTP POST and exposes it to the workflow	n8n Webhook node
Field Normalization	Maps the raw JSON payload into a flat, consistently named field set	n8n Set ("Edit Fields") node
Stage 1 Reasoning	Performs SOC L1 triage, validation, and Splunk-based investigation	LangChain Agent + Google Gemini
Log Correlation	Executes SIEM searches against relevant event codes and indicators	Splunk Search Job (tool)
Stage 2 Reasoning	Performs enrichment, finalizes classification/severity, documents findings	LangChain Agent + Google Gemini
Threat Intelligence	Looks up reputation data for IPs, domains, URLs, and file hashes	VirusTotal Lookup (tool)
Incident Management	Creates a formal incident record with the full investigation narrative	Jira Software (tool)
Notification	Informs stakeholders that an investigation has completed	Gmail node
Escalation Logic	Branches the workflow based on severity/classification	n8n IF node
L2 Escalation	Notifies Level 2 analysts of confirmed high-severity incidents	Gmail node
Connectivity	Bridges the cloud n8n instance to an on-premises Splunk instance	Cloudflare Tunnel

4.2 Design Principles

Several deliberate design principles shape the architecture beyond the node-by-node mechanics described in Section 5:

- Separation of concerns: triage/investigation (Stage 1) is kept distinct from enrichment/documentation (Stage 2), so each agent's system prompt, tool list, and failure modes stay easy to reason about independently.
- Evidence before judgment: neither agent is allowed to assert a classification or severity without first attempting to gather corroborating evidence from a real tool, and both must explicitly flag when evidence could not be gathered.
- Preserve upstream signal: pre-existing Classification/Severity values from the alert source are treated as informative priors rather than being discarded, reflecting the reality that upstream systems (mail gateways, EDR) often already carry useful triage signal.
- Fail loud, not silent: every guardrail is phrased as a required, visible statement ("Tool unavailable," "Information unavailable," "No matching Splunk events found") rather than a silent omission, so a reviewer reading the Jira ticket can immediately see where evidence is thin.
- Bounded autonomy: the agents may reason, investigate, classify, and recommend, but the boundary of automated action stops at ticket creation and notification — never at containment or remediation.

5. Detailed Workflow Walkthrough

This section walks through every node in the workflow in execution order, describing its configuration, purpose, and the data it produces for downstream nodes.

5.1 Webhook — Alert Intake

Attribute	Value
Node type	n8n-nodes-base.webhook
HTTP Method	POST
Path	/SOC-Alert
Trigger	Any external system (mail gateway, SIEM rule, EDR, manual test) can POST an alert as JSON

The webhook is the single entry point into the automation. It expects a JSON body containing the fields described in Section 7 (Alert Data Model). Because the webhook is public-facing, in a production deployment it should be protected with a shared secret, header-based authentication, or an n8n webhook authentication option, and should sit behind the same network boundary controls as any other alert-ingestion endpoint.

5.2 Edit Fields — Payload Normalization

Immediately after intake, an Edit Fields (Set) node maps the nested webhook body into a flat set of named fields: Alert_Type, Sender, Subject, Email_Body, URL, Source_ip, Hash, Classification, and Severity. This normalization step exists so that the downstream AI agents can reference alert attributes with simple, stable expressions rather than reaching into the raw webhook structure, and so that the workflow can accept alerts from multiple upstream sources as long as they are mapped to this common schema.

Two of the normalized fields — Classification and Severity — are notable: they allow an upstream system that has already performed some triage (for example, a mail security gateway that flagged an email as phishing) to pass a starting classification and severity into the workflow. Both AI agents are explicitly instructed to preserve these values unless they find clear contradictory evidence during investigation, which prevents the AI from silently downgrading a human- or system-provided severity rating.

5.3 SOC L1 Investigation Agent

This is the first of the two LangChain agent nodes. It is configured with a system message that casts it as an L1 SOC Analyst AI Agent and a user prompt template that injects the normalized alert fields. Its only tool, besides the Gemini language model itself, is a Splunk search-job tool. The full reasoning framework enforced by its system prompt is covered in Section 6.

5.4 AI Investigation & Enrichment Agent

The second agent receives the full text output of the first agent as its primary input, along with the original Classification and Severity values. Its system prompt requires it to enrich the findings using a VirusTotal lookup tool wherever an indicator (hash, IP, URL, or domain) is present, assemble a complete, standardized investigation document, and create a Jira incident containing that document. Its detailed behavior is covered in Section 6.

5.5 Gmail — Investigation Completed Notification

Once the second agent finishes, a Gmail node sends a notification indicating that the investigation has completed. This gives stakeholders (for example, the SOC L1 shift lead) real-time visibility into alert throughput without needing to poll Jira directly.

5.6 IF — Severity Check

A conditional branch evaluates the finalized classification and severity produced by the second agent. If the incident is not both a confirmed True Positive and High/Critical severity, the workflow ends after the completion notification. If it is, the workflow proceeds to the escalation branch.

5.7 Gmail — High-Severity Escalation to L2

When the severity check evaluates to true, a second Gmail node fires, addressed to the L2 escalation distribution point. The message embeds the full investigation output so that the L2 analyst receiving the escalation has complete context without needing to open Jira first, while the Jira ticket remains the system of record for the incident.

6. AI Agent Architecture — Reasoning Framework

The heart of this automation is not the orchestration plumbing but the reasoning discipline encoded into the two agents' system prompts. Both agents are built on the same underlying methodology, adapted from real SOC L1 practice, and both are constrained by the same evidentiary and safety guardrails.

6.1 The Eight-Stage SOC L1 Methodology

The first agent's system prompt encodes the investigation lifecycle as eight explicit stages, which the agent is instructed to follow for every alert:

8. **ALERT** — Understand the incoming security alert and identify the affected user, host, IP address, domain, URL, file hash, and other available indicators.
9. **TRIAGE** — Determine what happened, identify suspicious indicators, assess initial risk, and prioritize the alert.
10. **VALIDATE** — Determine whether the alert is legitimate, suspicious, or a likely false positive, validating indicators with available tools rather than assuming maliciousness.
11. **INVESTIGATE** — Use Splunk to search for related security events (authentication, process, network, DNS, file, and endpoint activity), and use VirusTotal, PhishTool, or Wireshark/tshark when those tools are available and relevant.
12. **CORRELATE** — Connect activity across users, hosts, IPs, processes, files, domains, URLs, and timestamps to build a coherent picture of what occurred.
13. **CLASSIFY** — Assign one of three classifications: True Positive, False Positive, or Suspicious / Requires Further Investigation, with an explicit rationale.
14. **SEVERITY** — Assign one of four severities: Low, Medium, High, or Critical, with a brief justification.
15. **ESCALATE / RESPOND** — Recommend the appropriate SOC L1 response and escalate confirmed or serious incidents to L2, while never automatically performing destructive or high-impact actions without human approval.

A final, ninth responsibility — **DOCUMENT** — requires the agent to produce a concise investigation summary suitable for a Jira incident, itemized into ten sections: Alert Summary, Initial Triage, Indicators of Interest, Splunk Investigation, Threat Intelligence Findings, Correlation Findings, Classification, Severity, Recommended Action, and Jira Investigation Summary.

6.2 Evidentiary Guardrails

Both agents share a set of hard constraints intended to keep the AI grounded in verifiable evidence rather than plausible-sounding fabrication. These constraints are worth stating explicitly because they are the primary control against a well-known failure mode of LLM-based security tooling — an agent inventing log entries or threat-intel verdicts that were never actually retrieved.

- Never invent Splunk, VirusTotal, PhishTool, Wireshark, or Jira results.
- Never claim an indicator of compromise (IOC) is malicious without supporting tool evidence.

- Clearly separate observed facts from assumptions in the written output.
- If a tool is unavailable, the agent must state "Tool unavailable" rather than guessing.
- If information is missing from the alert or tool response, the agent must state "Information unavailable."
- If Splunk returns no matching events, the agent must say so explicitly rather than implying a clean result means "safe."

6.3 Human-in-the-Loop Safety Boundary

Both agents are instructed that they may recommend a response — including escalation — but must not autonomously perform destructive or high-impact actions (such as disabling an account, isolating a host, or blocking network traffic). Any such action requires explicit human approval. This design choice keeps the automation squarely in the "detect, investigate, document, and recommend" category rather than the higher-risk "autonomously remediate" category, which is an appropriate boundary for an L1-scoped agent.

6.4 Stage 1 — SOC L1 Investigation Agent, In Detail

Attribute	Configuration
Node type	@n8n/n8n-nodes-langchain.agent
Language model	Google Gemini Chat Model
Tools available	Splunk ("Create a search job in Splunk")
Max iterations	10
Primary output	Free-text investigation narrative covering triage, validation, and Splunk findings

The agent's user-facing prompt explicitly restates the alert fields (Alert Type, Sender, Subject, Email Body, URL, Source IP, Hash) and instructs the agent to perform triage, initial validation, investigation, correlation, preliminary classification, severity assessment, and a recommended SOC L1 action. It is directed to use the Splunk tool for every alert without exception, and, specifically for failed-login alerts, to investigate Windows Event Code 4625 ("An account failed to log on").

6.5 Stage 2 — AI Investigation & Enrichment Agent, In Detail

Attribute	Configuration
Node type	@n8n/n8n-nodes-langchain.agent
Language model	Google Gemini Chat Model (separate model instance)
Tools available	VirusTotal Lookup (HTTP Request tool), Jira Software
Max iterations	10
Primary output	Finalized, structured investigation document; a created Jira incident

This agent is given the complete output of Stage 1 as context and is required to produce a final document with eleven explicit sections: Alert Details, Triage Findings, Splunk Investigation, VirusTotal Findings, Correlation Findings, Classification, Severity, Reason for Classification, Recommended SOC L1 Action, L2 Escalation, and a Final Investigation Summary. It must use the VirusTotal lookup tool for any available indicator (file hash, source IP, URL, or domain) and include the actual returned findings rather than a paraphrase or guess; if the lookup tool cannot verify an indicator, it must state "VirusTotal verification unavailable." Finally, it is required to create a Jira incident — project "SOC Security Operations," issue type "Incident" — with the complete investigation document placed in the ticket description.

6.6 Design Rationale — Why Two Agents Instead of One

An earlier, simpler design might have used a single agent with access to all four tools (Splunk, VirusTotal, Jira, and the language model). The two-agent split was chosen instead for several practical reasons observed during workflow design:

- Smaller tool surfaces per agent reduce the chance that the model skips a required tool call, since each agent has fewer competing options to choose from at each reasoning step.
- The Stage 1 → Stage 2 handoff creates a natural checkpoint: the Stage 1 narrative is captured as a discrete artifact before enrichment begins, which is useful for debugging and for auditing what the model "knew" before threat-intel lookups were performed.
- System prompts stay shorter and more focused per agent, which in practice makes instruction-following more reliable than a single, longer prompt trying to cover triage, enrichment, and documentation all at once.
- It mirrors real SOC practice, where an L1 analyst hands off a documented triage to whoever owns enrichment and ticketing, rather than one person performing every step in an undifferentiated block.

7. Alert Data Model

Every alert entering the workflow is normalized into the following flat schema before it reaches either AI agent. Keeping this schema stable is what allows the two agents' prompts to reference fields predictably regardless of the alert's original source.

Field	Type	Description
Alert_Type	string	Category of the alert, e.g. phishing, suspicious-URL, malicious-hash, failed-login.
Sender	string	Originating email address or system, where applicable (e.g. for phishing alerts).
Subject	string	Email subject line or short alert title.
Email_Body	string	Full body text of the reported email, when the alert is email-derived.
URL	string	A URL referenced in the alert, to be checked for reputation.
Source_ip	string	Source IP address associated with the activity, to be checked for reputation and correlated in Splunk.
Hash	string	File hash (e.g. SHA-256) associated with a suspicious attachment or binary.
Classification	string	Optional pre-existing classification supplied by the alert source; preserved unless contradicted by evidence.
Severity	string	Optional pre-existing severity supplied by the alert source; preserved unless contradicted by evidence.

Not every field is populated for every alert type — a suspicious-URL report may leave Hash empty, while a malicious-attachment report may leave URL empty. Both agents are instructed to state "Information unavailable" for any field that cannot be evaluated rather than fabricating a value.

8. External Integrations

8.1 Splunk — SIEM Correlation

The Stage 1 agent is equipped with a Splunk search-job tool that executes SPL queries against the connected Splunk index. The reference configuration in this workflow runs a search of the form shown below, targeting Windows security event codes associated with authentication failures.

```
search index=* EventCode=4625
```

Figure 2 — Representative Splunk search used for failed-login correlation

Connectivity from the cloud-hosted n8n instance to the Splunk deployment is provided by a Cloudflare Tunnel, which exposes the Splunk API to n8n without requiring inbound firewall rules on the Splunk host's network — an appropriate pattern when the SIEM lives on-premises or in a private network while the orchestration layer runs in the cloud.

8.2 VirusTotal — Threat Intelligence Enrichment

The Stage 2 agent uses an HTTP Request-based tool to query VirusTotal's reputation API for any indicator present in the alert: file hash, source IP, URL, or domain. The agent is required to reflect the actual VirusTotal verdict (e.g., detection ratio, known-malicious classifications) in the final investigation document, and to explicitly flag when verification could not be completed rather than omitting the section or guessing at a result.

8.3 Jira — Incident Management

On completion of enrichment, the Stage 2 agent creates a Jira incident using the Jira Software tool, targeting the "SOC Security Operations" project with issue type "Incident," and places the full, structured investigation narrative into the ticket's description field. This makes Jira the durable system of record for every investigated alert, independent of the email notifications, which are ephemeral by comparison.

8.4 Gmail — Notification and Escalation

Two distinct Gmail sends exist in the workflow: a general "Investigation Completed" notice fired after every investigation, and a conditional "High Severity Incident — Escalated to L2" notice fired only when the severity check passes. The escalation email embeds the complete investigation output inline so an L2 analyst can begin work immediately.

8.5 Google Gemini — Language Model Backbone

Both AI agent nodes are backed by Google Gemini chat models, connected via n8n's LangChain Google Gemini (PaLM API) credential type. Using separate model connections per agent keeps each agent's conversational context isolated to its own task.

8.6 Cloudflare Tunnel — Hybrid Connectivity

Because n8n runs in the cloud while Splunk runs locally in this deployment, a Cloudflare Tunnel provides an outbound-only, encrypted connection from the local network to Cloudflare's edge, which n8n Cloud can then reach. This avoids exposing the Splunk management interface directly to the internet while still allowing the cloud workflow to issue live searches against it.

9. Classification, Severity, and Escalation Logic

9.1 Classification Values

Classification	Meaning
True Positive	The investigation confirms the alert reflects genuine malicious or unauthorized activity.
False Positive	The investigation determines the alert does not reflect malicious activity (e.g., a legitimate but unusual login, a benign URL).
Suspicious / Requires Further Investigation	Evidence is inconclusive; the alert warrants further, typically L2, investigation before a final determination.

9.2 Severity Values

Severity	Typical Criteria
Low	Minimal potential impact; isolated or clearly contained activity; no evidence of lateral movement or data exposure.
Medium	Moderate potential impact; suspicious activity confirmed but limited in scope, or unconfirmed but concerning indicators.
High	Confirmed malicious activity with meaningful potential impact — e.g., a validated malicious hash executed on a host, or credential compromise indicators.
Critical	Confirmed malicious activity with severe or organization-wide potential impact, such as active data exfiltration or ransomware indicators.

9.3 Escalation Rule

The workflow's IF node gates the L2 escalation email on the finalized Classification and Severity produced by the Stage 2 agent. In this reference configuration, escalation is triggered when the incident is classified as True Positive and rated High (or Critical) severity — the combination that represents confirmed, meaningfully impactful malicious activity. Alerts that resolve to False Positive, or that remain Low/Medium severity, complete with only the standard notification and do not generate an L2 page.

Because both agents are instructed to preserve an upstream Classification/Severity value absent contradictory evidence, an alert source that has already flagged something as high-confidence and high-severity (for example, a mail gateway that caught a known-bad phishing kit) will reliably reach L2 escalation even if the AI's own independent evidence is thin — while still requiring the AI to document its own findings alongside that inherited judgment.

9.4 Classification / Severity Decision Reference

The following reference matrix illustrates how the two dimensions typically combine to drive the escalation decision described in Section 9.3.

Classification	Low / Medium Severity	High / Critical Severity
False Positive	Document and close; no escalation	Document and close; no escalation (re-verify severity assumptions)
Suspicious / Requires Further Investigation	Document; route to L1 backlog or L2 review at analyst discretion	Document; recommend expedited L2 review given the potential impact
True Positive	Document and close, or monitor per playbook	Escalate to L2 immediately via automated notification

10. Sample Investigation Walkthrough

To make the abstract flow concrete, this section traces a representative alert through the entire pipeline.

Step 1 — Alert Received

A mail security gateway detects a suspicious email containing a shortened URL and a ZIP attachment, and posts the following alert to the webhook: Alert_Type = "phishing", Sender = an external address, Subject = a shipping-notification lure, URL = the shortened link, Hash = the SHA-256 of the attachment, Classification = "Suspicious", Severity = "Medium".

Step 2 — Field Normalization

The Edit Fields node flattens the payload into the standard schema so both agents can reference Alert_Type, Sender, Subject, Email_Body, URL, Source_ip, Hash, Classification, and Severity directly.

Step 3 — Stage 1 Triage

The SOC L1 Investigation Agent reviews the alert, notes the presence of a URL and a file hash as the primary indicators, and queries Splunk for any endpoint or network activity correlated with the sender domain or the shortened URL's resolved destination. If no matching Splunk events exist, the agent records "No matching Splunk events found" rather than assuming the absence of evidence proves the email is benign.

Step 4 — Stage 2 Enrichment

The AI Investigation & Enrichment Agent takes the Stage 1 narrative and queries VirusTotal for the URL and the file hash. Suppose the hash returns a high detection ratio from multiple engines — the agent records this finding verbatim in the VirusTotal Findings section and, given confirmed-malicious evidence plus the ability to compromise a host, upgrades the working severity toward High while explaining the evidentiary basis for doing so.

Step 5 — Classification and Documentation

With a confirmed-malicious file hash, the agent classifies the incident as True Positive, assigns High severity, and assembles the eleven-section investigation document, explicitly stating that L2 escalation is required because of the confirmed malicious payload and potential for host compromise.

Step 6 — Jira Incident Creation

The agent creates a Jira incident in the "SOC Security Operations" project with the full document in the description, giving the SOC a durable, searchable record.

Step 7 — Notification and Escalation

A Gmail notice confirms the investigation is complete. Because the finalized classification is True Positive and the severity is High, the IF node evaluates to true and a second Gmail message escalates the incident to the L2 distribution point, embedding the full investigation text so the L2 analyst can act immediately.

11. Security and Governance Considerations

11.1 Credential Handling

All credentials — Splunk API access, the Google Gemini API key, VirusTotal API access, Jira authentication, and Gmail OAuth2 — are configured as n8n credential objects rather than embedded in node parameters or checked into any repository. This keeps secrets out of workflow exports and version control.

11.2 Webhook Exposure

Because the intake webhook is internet-reachable by design, production deployments should add authentication (a shared secret header, HMAC signature verification, or IP allow-listing at the Cloudflare edge) to prevent unauthenticated parties from injecting fabricated alerts that could trigger spurious Jira incidents or, worse, waste L2 analyst attention through false escalations.

11.3 Guardrails Against AI Hallucination

As detailed in Section 6.2, the system prompts explicitly forbid inventing tool results and require the agents to distinguish observed fact from assumption. This is a necessary but not sufficient control — periodic human audit of a sample of AI-generated Jira tickets against the underlying Splunk/VirusTotal evidence is recommended to catch any drift in agent behavior, especially after model version upgrades.

11.4 Human Approval for Response Actions

The workflow does not, and by design should not, take any containment or remediation action automatically. Recommended actions are documented for a human responder to execute. This bounds the blast radius of any single incorrect AI classification to "a ticket was created and an email was sent," rather than "a host was isolated" or "an account was disabled."

11.5 Data Handling

Alert content frequently includes potentially sensitive material — email bodies, sender addresses, internal IP addresses. This data flows through the Gemini API for processing and is stored in Jira and in email. Organizations adopting this pattern should review the data-processing terms of their LLM provider and ensure Jira project permissions restrict visibility of incident tickets to authorized SOC personnel.

11.6 Compliance and Audit Trail

Because every investigation produces a Jira incident containing the full evidentiary narrative — including explicit statements when evidence was unavailable — the workflow generates a natural audit trail suitable for compliance review. Organizations subject to regulatory reporting requirements around security incidents (breach notification timelines, for example) should ensure the Jira project's audit log and retention

settings meet applicable record-keeping obligations, and should periodically export or archive incident records outside of Jira's own retention window if required.

12. Testing and Validation Approach

Validating an agentic workflow like this one requires testing both the deterministic plumbing (webhook, field mapping, conditional branch) and the non-deterministic AI reasoning steps. A layered approach is recommended:

16. Unit-level node testing: trigger the webhook with a small set of synthetic payloads covering each Alert_Type, and confirm the Edit Fields node maps every field correctly, including cases where optional fields (URL, Hash) are absent.
17. Tool-availability testing: temporarily disable or misconfigure the Splunk or VirusTotal credentials to confirm the agents correctly report "Tool unavailable" rather than fabricating results.
18. Evidence-grounding spot checks: for a sample of test alerts, manually verify that every claim in the agent's Splunk Investigation and VirusTotal Findings sections traces back to an actual query result, not an inference.
19. Classification consistency testing: submit alerts with and without a pre-populated Classification/Severity to confirm the "preserve unless contradicted" rule behaves as intended in both directions.
20. Escalation-path testing: submit alerts engineered to land in each quadrant of the classification/severity matrix and confirm the IF node routes only True-Positive/High (or Critical) alerts to the L2 escalation email.
21. End-to-end regression testing: after any change to either system prompt, replay a fixed regression set of historical or synthetic alerts and diff the resulting Jira documents against a prior known-good baseline.

13. Known Limitations and Observations

- Event-code discrepancy: the Stage 1 system prompt directs the agent to investigate Windows Event Code 4625 for failed logins, while the underlying reference Splunk search job in this build is configured for EventCode=4525. This mismatch should be reconciled — 4625 is the standard Windows "account failed to logon" event, and the search-job configuration should be aligned to it (or intentionally documented if 4525 maps to a different, deliberately targeted event source in the deployer's environment).
- Hardcoded test values: the reference Stage 2 prompt contains a testing directive stating that "Classification must remain True Positive and Severity must remain High" for the purposes of validating the escalation path. This should be removed or parameterized before the workflow is used against live alerts, since it would otherwise force every incident to the highest classification and severity regardless of actual findings.
- Single-model dependency: both agents rely on Google Gemini; an outage or rate-limit event on that provider would stall the entire pipeline. A fallback model or queuing/retry strategy is not currently defined.
- No automated deduplication: the workflow does not currently check whether an incoming alert duplicates or relates to an already-open Jira incident, which could result in multiple tickets for the same underlying campaign.
- Limited indicator coverage: PhishTool and Wireshark/tshark are referenced in the Stage 1 system prompt as available tools "when available," but are not wired into this reference build — only Splunk (Stage 1) and VirusTotal plus Jira (Stage 2) are actually connected.
- Webhook authentication: as noted in Section 11.2, the intake webhook does not currently enforce authentication, which should be addressed before production use.

14. Future Enhancements

22. Add PhishTool and Wireshark/tshark integrations to give the Stage 1 agent genuine phishing-specific and packet-level investigation capability, matching what its system prompt already anticipates.
23. Introduce alert deduplication and campaign clustering, so that repeated alerts tied to the same phishing campaign or the same malicious IP are grouped under a single Jira incident with cumulative evidence rather than generating duplicate tickets.
24. Add a Slack or Microsoft Teams notification channel alongside Gmail for faster analyst visibility, particularly for L2 escalations.
25. Build a lightweight dashboard (or a Splunk/Jira report) tracking automation KPIs: alert volume by type, average time from intake to Jira creation, classification distribution, and escalation rate.
26. Introduce a confidence score alongside classification, allowing the workflow to route low-confidence "Suspicious" incidents to a human-review queue before Jira creation, rather than always auto-creating a ticket.
27. Add signed/authenticated webhook intake (HMAC or shared-secret header validation) to close the exposure noted in Section 11.2.

28. Periodically re-validate AI-generated investigation documents against ground truth to detect model drift, particularly after upgrading the underlying Gemini model version.
29. Extend severity/classification logic to support partial automated response for very low-risk, high-confidence False Positive cases (e.g., auto-closing a ticket with a documented rationale), while keeping all containment actions human-approved.

15. Skills Demonstrated

This project draws on and demonstrates competency across several disciplines relevant to modern security operations and AI engineering:

Domain	Specific Skills
SOC Operations	L1 alert triage, SIEM investigation methodology, IOC handling, incident classification and severity assessment
Threat Intelligence	IOC enrichment workflows, reputation-based validation using VirusTotal
Security Automation	SOAR-style workflow design, low-code orchestration with n8n, conditional escalation logic
Agentic AI Engineering	System-prompt design for tool-using LLM agents, evidentiary guardrails, multi-agent pipeline decomposition
Incident Management	Structured incident documentation, Jira ticket automation, L2 escalation handoff design
Systems Integration	Webhook-based intake, hybrid cloud-to-on-premises connectivity via Cloudflare Tunnel, multi-tool orchestration

16. Roles and Responsibilities

Although the workflow automates a substantial portion of L1 triage, it is designed to operate alongside human roles rather than replace them. The table below outlines how responsibility is distributed across the automation and the human SOC team.

Role	Responsibility
Stage 1 AI Agent	Initial triage, Splunk-based log correlation, preliminary classification and severity, and a draft investigation narrative.
Stage 2 AI Agent	Threat-intelligence enrichment, final classification/severity determination, structured documentation, and Jira incident creation.
SOC L1 Analyst (human)	Periodic quality review of AI-generated tickets, handling of alerts the automation cannot classify confidently, and execution of any recommended low-risk actions.
SOC L2 Analyst (human)	Deep investigation of escalated True-Positive/High-severity incidents, coordination of containment and remediation, and decisions requiring human approval.
Automation Owner / Engineer	Maintains the n8n workflow, credentials, and tool integrations; tunes system prompts; reconciles known limitations such as those in Section 13; monitors for model drift.
Security Leadership	Defines the severity/escalation thresholds, approves changes to what the automation is permitted to do, and reviews aggregate metrics on automation performance.

This division keeps the automation's role explicitly bounded to detection, investigation, and documentation, while every decision with real-world consequence — approving a remediation action, closing an ambiguous case, or overriding an AI classification — remains with a named human role.

17. Conclusion

This project demonstrates a practical, end-to-end pattern for applying agentic AI to SOC L1 operations: alerts are ingested, investigated against real log and threat-intelligence data, classified using a consistent rubric, documented in a durable ticketing system, and escalated to human responders when the evidence warrants it — all while keeping any high-impact response action strictly under human control. The two-stage agent design, with narrowly scoped tools and explicit evidentiary guardrails at each stage, offers a template that can be extended with additional data sources (PhishTool, packet capture, EDR telemetry) and additional response channels without fundamentally changing the underlying investigation methodology.

The known limitations identified in Section 13 — particularly the event-code mismatch and the hardcoded test classification — represent straightforward next steps before the workflow should be relied upon against live production alerts. With those addressed, alongside the enhancements outlined in Section 14, this architecture provides a credible foundation for a lightweight, AI-assisted SOC L1 automation capability.

Appendix A — Sample Alert Payload

The following illustrates a representative (synthetic) JSON payload posted to the intake webhook for a phishing-style alert, matching the schema described in Section 7.

```
{
  "alert_type": "phishing",
  "sender": "billing-support@example-delivery.com",
  "subject": "Your package could not be delivered",
  "body": "Please confirm your address by clicking the link below...",
  "url": "hxxp://short-link[.]example/xk29a",
  "source_ip": "203.0.113.44",
  "hash": "e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b85",
  "classification": "Suspicious",
  "severity": "Medium"
}
```

Figure 3 — Representative webhook intake payload (synthetic example data)

Appendix B — Repository Structure

```

AI-SOC-L1-Automation/
├── workflow/
│   └── SOC-L1-Investigation.json
├── screenshots/
│   ├── n8n-workflow.png
│   ├── splunk-investigation.png
│   ├── virustotal-enrichment.png
│   ├── ai-investigation.png
│   ├── jira-incident.png
│   ├── investigation-completed.png
│   └── l2-escalation.png
├── README.md
└── .gitignore

```

The repository intentionally excludes API keys, passwords, authentication tokens, and any other sensitive credentials; all credentials are configured separately within the n8n instance's credential store.

Appendix C — Tools & Technologies Reference

Technology	Purpose
n8n Cloud	Workflow automation and orchestration platform hosting the entire pipeline
Google Gemini	Large language model powering both AI investigation agents
Splunk	SIEM platform used for log search and security event correlation
VirusTotal	Threat-intelligence service used for IOC (IP, domain, URL, hash) reputation lookups
Jira	Incident-tracking system used to record and manage each investigated alert
Gmail	Email channel used for investigation-completion and L2-escalation notifications
Cloudflare Tunnel	Secure, outbound-only connectivity bridge between cloud n8n and the local Splunk instance

Appendix D — Glossary of Terms

Term	Definition
------	------------

SOC	Security Operations Center — the team and function responsible for monitoring, detecting, and responding to security events.
L1 / L2	Tiered analyst levels; L1 performs initial triage, L2 performs deeper investigation and handles escalated incidents.
SIEM	Security Information and Event Management — a platform (e.g., Splunk) that aggregates and allows searching of log/event data.
IOC	Indicator of Compromise — an artifact (IP, domain, URL, file hash, etc.) observed in connection with malicious activity.
True Positive	A classification confirming that an alert reflects genuine malicious or unauthorized activity.
False Positive	A classification indicating an alert does not reflect malicious activity.
Agentic AI	An AI system that can autonomously decide which tools to invoke and in what sequence, in pursuit of a defined objective.
Webhook	An HTTP endpoint that allows an external system to push data into a workflow in real time.
EventCode 4625	A Windows Security event code recorded when an account fails to log on.
SOAR	Security Orchestration, Automation and Response — a category of tools/platforms for automating security workflows, of which this n8n-based system is a lightweight example.

— End of Document —